

UD4 - Prácticas: fortificación de hosts

Configuración segura, cifrado, auditoría y monitorización de una máquina virtual Linux.

Datos de las prácticas	Información
Módulo	Seguridad y Alta Disponibilidad
Curso	2.º ASIR
Modalidad	Semipresencial
Duración estimada	10 horas
Entorno	Máquina virtual Linux propia

1. Objetivos

Al finalizar el itinerario, el alumnado será capaz de:

- Inventariar servicios, puertos, usuarios y permisos de un host Linux.
- Aplicar el principio de mínimo privilegio a usuarios, grupos y ficheros.
- Configurar el acceso SSH con claves y restricciones básicas.
- Crear y utilizar un volumen LUKS exclusivamente de entorno de pruebas.
- Actualizar el sistema y analizar recomendaciones de seguridad con Lynis.
- Revisar registros y recursos locales, e interpretar alertas de monitorización.
- Documentar medidas de fortificación y justificar su aplicación.

2. Alcance y preparación

Realiza todas las tareas en una máquina virtual propia y crea una *snapshot* inicial llamada **ud4-inicio**. No apliques comandos de cifrado, borrado, escaneo ni modificación de SSH a equipos ajenos, sistemas de producción o discos con datos personales.

1. Actualiza el sistema e instala las herramientas básicas:

```
# AlmaLinux, Rocky Linux o Fedora
sudo dnf update -y
sudo dnf install openssh-server lynis cryptsetup htop -y

# Debian o Ubuntu
sudo apt update && sudo apt upgrade -y
sudo apt install openssh-server lynis cryptsetup htop -y
```

2. Crea un directorio para las evidencias de texto:

```
mkdir -p ~/ud4-evidencias
```

```
chmod 700 ~/ud4-evidencias
```

3. Práctica 1 - Inventario, usuarios y permisos

3.1. Inventario inicial

Guarda un inventario básico del host antes de modificarlo:

```
hostnamectl | tee ~/ud4-evidencias/hostname.txt  
id | tee ~/ud4-evidencias/usuario-actual.txt  
ss -tulnp | tee ~/ud4-evidencias/puertos.txt  
systemctl list-units --type=service --state=running | tee ~/ud4-evidencias/servicios.txt
```

Identifica qué servicio escucha en cada puerto y señala uno que podría deshabilitarse si no fuera necesario para la función del equipo.

3.2. Mínimo privilegio

1. Crea un grupo y dos usuarios de entorno de pruebas:

```
sudo groupadd proyecto-ud4  
sudo useradd -m -G proyecto-ud4 lorena  
sudo useradd -m alumno-prueba
```

2. Crea un directorio compartido solo por el grupo y verifica el acceso:

```
sudo mkdir -p /srv/proyecto-ud4  
sudo chown root:proyecto-ud4 /srv/proyecto-ud4  
sudo chmod 2770 /srv/proyecto-ud4  
ls -ld /srv/proyecto-ud4
```

3. Explica el significado del bit especial 2 en 2770 y por qué 777 no sería apropiado. Comprueba que el usuario lorena pertenece al grupo y que alumno-prueba no puede crear ficheros en el directorio.

4. Práctica 2 - Fortificación del acceso SSH

4.1. Claves y configuración

Usa una segunda máquina virtual o una segunda sesión para mantener acceso al servidor mientras cambias la configuración.

1. Genera una clave en el cliente y copia solo la clave pública al servidor:

```
ssh-keygen -t ed25519 -C "lorena-ud4"  
ssh-copy-id lorenna@IP_SERVIDOR  
ssh lorenna@IP_SERVIDOR
```

2. En el servidor, crea un fragmento de configuración. Sustituye **lorena** por el usuario autorizado:

```
sudo tee /etc/ssh/sshd_config.d/ud4-hardening.conf > /dev/null << 'EOF'  
PermitRootLogin no  
PasswordAuthentication no  
PubkeyAuthentication yes  
AllowUsers lorenna  
MaxAuthTries 3  
EOF  
sudo sshd -t  
sudo systemctl reload sshd
```

En Debian o Ubuntu, el servicio puede llamarse **ssh**; adapta solo el último comando si fuera necesario. Verifica la conexión con clave desde otra sesión antes de cerrar la actual. Guarda una copia del fragmento de configuración y explica qué riesgo mitiga cada directiva.

4.2. Revisión de accesos

Consulta intentos de acceso y sesiones actuales:

```
last -a | head -n 20  
sudo journalctl -u sshd --since "today" || sudo journalctl -u ssh --since "today"
```

Indica qué eventos revisarías ante varios fallos de inicio de sesión consecutivos.

5. Práctica 3 - Cifrado LUKS de un volumen de entorno de pruebas

Esta práctica requiere un disco virtual adicional vacío, por ejemplo **/dev/sdb**. Confirma el nombre con **lsblk** y no continúes si el dispositivo contiene particiones o datos que necesites conservar.

1. Identifica el disco adicional:

```
lsblk -o NAME,SIZE,TYPE,MOUNTPOINTS
```

2. Cifra, abre y crea un sistema de archivos en el disco de entorno de pruebas:

```
sudo cryptsetup luksFormat /dev/sdb  
sudo cryptsetup open /dev/sdb ud4-cifrado  
sudo mkfs.ext4 /dev/mapper/ud4-cifrado
```

```
sudo mkdir -p /mnt/ud4-cifrado
sudo mount /dev/mapper/ud4-cifrado /mnt/ud4-cifrado
echo "Dato de prueba" | sudo tee /mnt/ud4-cifrado/evidencia.txt
```

3. Comprueba el estado, desmonta y cierra el volumen:

```
sudo cryptsetup status ud4-cifrado
sudo umount /mnt/ud4-cifrado
sudo cryptsetup close ud4-cifrado
```

Documenta las fases de creación, apertura, montaje, acceso, desmontaje y cierre. Explica cómo custodiarías una clave de recuperación y por qué el cifrado no sustituye las copias de seguridad.

6. Práctica 4 - Actualización y auditoría con Lynis

6.1. Actualización controlada

Registra las actualizaciones disponibles, aplica las correspondientes y reinicia solo si el sistema lo solicita:

```
# AlmaLinux, Rocky Linux o Fedora
sudo dnf check-update || true
sudo dnf update -y

# Debian o Ubuntu
sudo apt update
apt list --upgradable
sudo apt upgrade -y
```

Anota qué comprobaciones realizarías antes de actualizar un servidor crítico: copias, ventana de mantenimiento, dependencias, plan de reversión y validación posterior.

6.2. Auditoría local

1. Ejecuta Lynis en la máquina virtual:

```
sudo lynis audit system | tee ~/ud4-evidencias/lynis-inicial.txt
```

2. Selecciona cinco recomendaciones. Para cada una, indica el riesgo, la medida propuesta, si es aplicable al entorno y el resultado tras revisarla. No apliques cambios que no comprendas ni que puedan impedir el arranque o acceso a la máquina.

3. Repite la auditoría tras aplicar únicamente mejoras seguras y documentadas.

7. Práctica 5 - Monitorización centralizada con Wazuh

Esta práctica se realiza solo con un servidor Wazuh proporcionado por el docente y una máquina virtual propia. No registres equipos ajenos ni modifiques reglas globales de la plataforma.

7.1. Instalación y registro del agente

1. Obtén del docente la dirección del servidor Wazuh, el método de registro y el grupo asignado al agente.
2. Instala el agente siguiendo la [documentación oficial de Wazuh](#) para tu distribución.
3. Comprueba que el servicio está activo y guarda la evidencia:

```
sudo systemctl status wazuh-agent --no-pager | tee ~/ud4-evidencias/wazuh-  
agente.txt  
sudo journalctl -u wazuh-agent --since "today" --no-pager | tail -n 30 | tee  
~/ud4-evidencias/wazuh-registro.txt
```

4. En el panel de Wazuh, verifica que el agente aparece conectado. Registra el nombre del host, la dirección privada asignada, el grupo y la hora de la última conexión.

7.2. Eventos y supervisión de integridad

1. Realiza un único inicio de sesión fallido contra tu propia cuenta y localiza la alerta correspondiente en Wazuh. Anota la regla, nivel, hora, usuario y host.
2. Crea un fichero de prueba en un directorio supervisado por el agente según la configuración facilitada por el docente. Comprueba que Wazuh informa del cambio de integridad y conserva una captura o exportación de la alerta.
3. Para cada alerta, explica qué evidencia aporta, qué posible impacto tiene y cuál sería la primera medida de contención.

Si no hay servidor Wazuh disponible, utiliza una demostración o un informe de ejemplo proporcionado por el docente. Identifica en él el agente, la regla, el nivel de alerta, la fuente del evento y la acción recomendada.

8. Práctica 6 - Monitorización local y registros

8.1. Recursos y servicios

Observa el estado del host y registra una evidencia de cada comando:

```
htop  
df -h  
free -h  
systemctl --failed  
ss -tulnp
```

Identifica un proceso, un servicio, una conexión o puerto en escucha, y el uso de disco y memoria. Distingue entre un estado normal y un dato que requeriría investigación.

8.2. Logs y eventos controlados

Consulta eventos recientes y los del servicio SSH:

```
sudo journalctl -xe --no-pager | tail -n 50  
sudo journalctl -u sshd --since "today" || sudo journalctl -u ssh --since "today"
```

Genera un único fallo de autenticación contra tu propia cuenta de entorno de pruebas y localiza el evento correspondiente. Documenta hora, servicio, usuario y resultado; no realices ataques de fuerza bruta.

10. Autoevaluación

1. ¿Qué objetivo principal tiene el hardening?
2. ¿Qué principio establece que un usuario debe disponer solo de los permisos necesarios?
3. ¿Qué diferencia existe entre autenticación y autorización?
4. ¿Qué riesgo mitiga Secure Boot?
5. ¿Qué protege principalmente el cifrado de disco?
6. ¿Por qué una clave privada SSH no debe compartirse?
7. ¿Para qué sirve Lynis?
8. ¿Qué etapas forman el ciclo de gestión de vulnerabilidades?
9. ¿Qué información pueden proporcionar los logs?
10. ¿Qué función puede realizar Wazuh?
11. ¿Qué diferencia existe entre un IDS y un IPS?
12. ¿Por qué es importante comprobar una actualización después de desplegarla?
13. ¿Qué riesgos presenta un servicio innecesario expuesto a Internet?
14. ¿Por qué un análisis de vulnerabilidades requiere autorización previa?

11. Tarea evaluable única - Fortificación de un servidor

Entrega un informe en PDF o Markdown con capturas propias y explicaciones redactadas con tus palabras de la práctica de WAZUH.

12. Recursos

- [CIS Benchmarks](#)
- [Documentación de OpenSSH](#)
- [Cryptsetup y LUKS](#)
- [Lynis](#)
- [Greenbone Community Edition](#)
- [Wazuh](#)
- [OpenSCAP](#)
- [CISA: Secure by Design](#)